

Access Control Policy

Application: Personal Budget Application (Coffer) | **Owner:** Randall Miller (randallsm83@gmail.com) | **Version:** 1.0 | **Effective Date:** March 18, 2026 | **Review Cycle:** Annually

1. PURPOSE AND SCOPE

This Access Control Policy defines how access to the Personal Budget Application ("Coffer"), its production infrastructure, and consumer financial data is granted, managed, and revoked. It applies to all consumers using the Application and to the application owner who administers the infrastructure.

2. ROLES AND ACCESS LEVELS

Role	Description	Access Level
Authenticated User	A registered consumer who has completed login	Read/write access to their own data only
Unauthenticated User	Any visitor who has not completed login	No access to application data or features
Application Owner / Admin	Randall Miller — infrastructure and codebase access	Full administrative access to all systems

3. CONSUMER AUTHENTICATION REQUIREMENTS

- All consumers must authenticate using a valid email address and password before accessing any application data.
- Passwords must meet a minimum length of 8 characters.
- Passwords are stored as bcrypt hashes (cost factor 10+); plaintext passwords are never retained.
- Multi-factor authentication (TOTP via authenticator app) is available to all users and enforced upon enablement.
- Sessions use signed JWTs managed by Auth.js; session tokens expire and are invalidated on sign-out.
- All unauthenticated requests to protected routes are redirected to the login page.

4. AUTHORIZATION MODEL

- All database queries include a `userId` filter scoped to the authenticated user's session ID. A user cannot read or modify data belonging to any other user.
- Server-side session validation is performed on every API request and server action.
- There is no concept of shared data or cross-user visibility within the application.
- Plaid bank connections are scoped to the user who initiated them and cannot be accessed by other users.

5. ADMINISTRATIVE ACCESS CONTROLS

- Access to production infrastructure (Vercel, Neon, GitHub) is restricted to the application owner.
- All administrative accounts are protected by multi-factor authentication (MFA).
- Database connection strings and API secrets are stored as encrypted environment variables in Vercel.
- SSH access to any external services uses SSH keys managed by 1Password SSH agent, protected by biometric/passkey authentication.
- No third-party contractors or employees have access to production systems or consumer data.

6. ACCESS PROVISIONING AND DEPROVISIONING

- **Provisioning:** New user accounts are created via the Application's registration flow (invite-only). Each account is assigned a unique UUID and scoped credentials.
- **Deprovisioning:** Users may request account deletion at any time. Upon request, all associated data is permanently deleted within 30 days, Plaid connections are revoked, and the account record is removed. The user immediately loses the ability to authenticate.
- **Session invalidation:** Users may sign out at any time, invalidating their current session token.

7. ACCESS REVIEWS

Administrative access to production systems (Vercel, Neon, GitHub) is reviewed annually by the application owner. Any unnecessary access or stale credentials are revoked during the review. This policy is also reviewed annually and updated as needed.

Next scheduled review: March 2027

8. LEAST PRIVILEGE

Access rights are granted on a least-privilege basis. Authenticated users may only access their own data. The application server accesses the database using a connection-string credential with the minimum permissions required for application operation. No administrative database credentials are used at runtime.

Acknowledged and approved by:

Randall Miller

Signature

Randall Miller

Printed Name

March 18, 2026

Date